GUÍA DE HACKING ÉTICO Y CIBERSEGURIDAD

Autor: BoostPro

Versión: 1.0 Uso:

Educativo y Legal

Importante: Esta guía está diseñada únicamente para fines educativos y auditorías autorizadas.

INTRODUCCIÓN

El Hacking Ético es el proceso de analizar sistemas, redes y aplicaciones con el objetivo de identificar debilidades de seguridad, siempre bajo autorización. A diferencia del hacking malicioso, el hacking ético se realiza con fines de prevención, protección y fortalecimiento de infraestructuras tecnológicas.

Hoy en día, las amenazas digitales han crecido enormemente: robo de contraseñas, ransomware, estafas por correo, phishing, malware, vulnerabilidades en sitios web y filtraciones masivas de información. Por eso, aprender hacking ético es una habilidad altamente demandada en el mundo laboral.

Esta guía tiene como objetivo introducirte a los conceptos fundamentales del hacking ético, buenas prácticas y metodología profesional, para que puedas aprender seguridad informática de manera responsable.

Objetivos principales:
- Entender qué es el hacking ético.
- Conocer los principales tipos de ataques (solo a nivel conceptual).
- Aprender cómo se realiza una auditoría de seguridad.
- Aplicar buenas prácticas para proteger equipos y redes.
- Conocer herramientas utilizadas en pentesting (sin uso ofensivo).

ÉTICA, LEY Y RESPONSABILIDAD

El primer paso en hacking ético es comprender que la seguridad informática está directamente relacionada con la ley. Realizar pruebas sin permiso puede considerarse delito, aunque el objetivo sea “aprender”.

¿Cuándo es legal practicar hacking?
Es legal cuando:
- Tienes autorización explícita del dueño del sistema.
- Trabajas en un laboratorio personal (máquinas virtuales propias).
- Participas en plataformas de entrenamiento legal como CTF (Capture The Flag).
- Estás en programas de Bug Bounty autorizados.

¿Cuándo es ilegal?
- Escanear redes ajenas sin permiso.
- Intentar acceder a sistemas de terceros.

- Probar vulnerabilidades en páginas web públicas sin autorización.
- Descargar bases de datos filtradas.
- Forzar contraseñas de cuentas reales.

Regla de oro del hacking ético:
Si no tienes permiso por escrito, no lo hagas.

El hacking ético se basa en responsabilidad. Un profesional de seguridad protege, documenta y reporta vulnerabilidades para mejorar la infraestructura.

CONCEPTOS CLAVES DE CIBERSEGURIDAD

Para avanzar en hacking ético necesitas dominar los conceptos base.

CIA: Confidencialidad, Integridad y Disponibilidad
- Confidencialidad: solo personas autorizadas acceden a la información.
- Integridad: los datos no se alteran sin permiso.
- Disponibilidad: los sistemas deben estar accesibles cuando se necesitan.

Autenticación vs Autorización
- Autenticación: confirmar identidad (usuario/contraseña).
- Autorización: permisos que tienes dentro del sistema.

Vulnerabilidad, Amenaza y Riesgo
- Vulnerabilidad: fallo o debilidad.
- Amenaza: actor o evento que puede explotar una debilidad.
- Riesgo: impacto potencial de esa amenaza.

Ingeniería Social Uno de los ataques más peligrosos no es técnico: es psicológico. Manipular a una persona para que entregue información sigue siendo una de las técnicas más usadas en el mundo real.

TIPOS DE ATAQUES MÁS COMUNES (TEORÍA)

Conocer los ataques ayuda a defenderse.

Phishing: Correos o mensajes falsos para robar credenciales.

Malware: Programas maliciosos como troyanos, spyware y ransomware.

Ataques a contraseñas: La mayoría de brechas ocurre por contraseñas débiles o repetidas.

Vulnerabilidades web: Errores en sitios web que permiten acceso indebido, robo de datos o modificación de contenido.

Ataques a redes: Incluyen interceptación de tráfico o configuraciones inseguras.

Importante: un hacker ético estudia esto para prevenir, no para atacar.

METODOLOGÍA PROFESIONAL DE PENTESTING

Un pentest profesional no es “probar cosas”. Se hace con orden.

Fases principales de un pentest ético:
1. Definición del alcance
2. Reconocimiento (información pública)
3. Análisis y enumeración
4. Evaluación de vulnerabilidades
5. Pruebas controladas (solo autorizado)
6. Documentación y reporte
7. Recomendaciones y mejoras
8. Verificación final

Definir alcance es obligatorio.
Debe quedar claro qué se puede probar, qué no se puede tocar, horarios permitidos, impacto permitido y forma de reporte.

Esto protege tanto al auditor como a la empresa.

LABORATORIO SEGURO PARA PRACTICAR

La forma correcta de aprender hacking ético es en un entorno aislado.

¿Qué necesitas para practicar legalmente?
- Un PC con buena RAM (mínimo 8GB recomendado)

- VirtualBox o VMware
- Máquinas virtuales de práctica
- Un entorno sin conexión a redes ajenas

Plataformas recomendadas (legales):
- Hack The Box
- TryHackMe
- PortSwigger Web Security Academy
- OverTheWire

¿Por qué usar laboratorio?
Porque un error en un sistema real puede causar daño, cortar servicios o generar delitos informáticos.

SEGURIDAD EN WINDOWS (MEJORAS CLAVES)

Windows es el sistema más atacado del mundo por su popularidad.

Recomendaciones esenciales:
- Activar Windows Defender
- Mantener Windows Update al día
- Usar firewall activado
- Evitar software pirata
- Revisar programas de inicio

Contraseñas fuertes y MFA:
Usa contraseñas largas con combinación de letras, números y símbolos. Ideal: 12 caracteres o más.
Y siempre que sea posible, usa MFA/2FA.

Recomendación profesional: un password manager es clave para evitar repetir claves.

SEGURIDAD EN REDES WI-FI

La red doméstica es un objetivo frecuente.

Cómo proteger tu Wi-Fi:
- Usar WPA2 o WPA3

- Cambiar contraseña por defecto del router
- Cambiar usuario admin del router
- Desactivar WPS
- Actualizar firmware del router

Segmentación:
Separar dispositivos en redes distintas (invitados, IoT, principal).

Buenas prácticas:
- No compartir claves a cualquiera
- No conectarse a Wi-Fi públicas para banca o datos sensibles
- Usar VPN en redes desconocidas

SEGURIDAD WEB Y BUENAS PRÁCTICAS

Muchos ataques actuales ocurren en páginas web.

Buenas prácticas para sitios web:
- Usar HTTPS con certificado SSL válido
- Mantener CMS actualizado (WordPress, plugins)
- Usar autenticación fuerte
- Limitar intentos de login
- Realizar backups automáticos

Protección recomendada:
- WAF
- Captcha
- monitoreo de logs
- detección de accesos sospechosos

Una web vulnerable puede provocar robo de datos, pérdida de reputación y sanciones legales.

HERRAMIENTAS DE UN PROFESIONAL (ENFOQUE LEGAL)

Un profesional de ciberseguridad usa herramientas para auditar y proteger.

Herramientas comunes:
- Wireshark
- Nmap
- Burp Suite
- Metasploit (solo laboratorio)
- Kali Linux
- OpenVAS / Nessus
- Password Managers: Bitwarden, KeePass

Nota importante: El valor real no está en la herramienta, sino en la metodología, análisis y reporte.

RUTA DE APRENDIZAJE Y CONCLUSIÓN

Aprender hacking ético es un camino largo, pero muy rentable.

Ruta recomendada:
1. Fundamentos de redes (TCP/IP, DNS, HTTP/HTTPS)
2. Linux básico y comandos esenciales
3. Seguridad en Windows
4. Programación básica (Python recomendado)
5. Fundamentos web (HTML, JS, SQL)
6. OWASP Top 10
7. Práctica en laboratorios CTF
8. Certificaciones futuras

Certificaciones populares:
- CompTIA Security+
- CEH
- eJPT
- OSCP

Conclusión:
El hacking ético no se trata de atacar, se trata de entender cómo piensa un atacante para proteger sistemas. Un profesional de seguridad es un protector digital.

Practica siempre en laboratorios legales y enfócate en aprender fundamentos. La disciplina y la ética son la diferencia entre un criminal y un profesional.

BoostPro.cl

Soluciones Tecnológicas & Desarrollo de Software